PROMETHEUS · MENTOR REVIEW

OCS Intelligence LLM Deep Audit & Project Review

A full examination of the capstone — security, configuration, code quality, live service health, and the road to the showcase.

Team: Open Coding Society, Del Norte High School (Poway USD)
Mentor: Eddie Revollo, Prometheus · **Teacher:** John Mortensen
Date: October 14, 2026

EXECUTIVE SUMMARY

Strong bones. Weak operations.

- **The service's engine works.** Verified live today: the API path — gateway, queue, orchestrator — answers correctly end-to-end.
- **The storefront is down.** The student-facing web interface returns 502, and has likely been down unnoticed — the status page was last verified 26 days ago.
- **The engineering is real:** perfect secret hygiene across all 30 commits, a 16/16 passing test suite, thoughtful service hardening.
- **The discipline lapsed after September 30:** no code, no evidence, no weekly reports since — while hardware work continued off the record.
- **This audit:** 2 High security findings, 1 High configuration finding, 1 real concurrency bug — all fixable, all teachable.

CREDIT WHERE DUE

What the team got right

- **Zero secrets leaked — ever.** Full scan of the tree and all 30 commits of history: every key value is a placeholder. Rare discipline at any level.
- **Tests pass.** Their offline suites ran clean in this audit: 16 passed, 0 failed (gateway lanes + benchmark math).
- **Honest measurement.** The Sep 17 API test (9/9) and Sep 18 deployment log recorded real numbers — including the unflattering ones.
- **Real hardening:** services sandbox themselves (no new privileges, protected filesystem, private tmp) and restart on failure.
- **An honest threat model.** Their own security doc names most of the gaps this audit confirms. Self-awareness is the hardest skill.
- **Logging hygiene:** no keys, no prompts, no auth headers in any log line, anywhere.

SECURITY AUDIT

Two findings that matter most

- HIGH **Authentication fails open.** If the key list is ever empty, both the gateway and the rig's orchestrator accept any token — access control defaults to off, on both tiers.
- HIGH **Orchestrator exposed to every network peer.** The rig service listens on all interfaces with no firewall rule — any peer bypasses the fair queue and its limits entirely. Their own threat model lists it as open.
- MED **Services run as root** on both hosts, and operators SSH in as root — no per-person accountability if anything is compromised.
- MED **One shared key for all students** — no individual keys, quotas, or revocation. A leak exposes everyone at once.
- LOW **Key comparison isn't constant-time**; internal network addresses and GPU IDs are published in the public repo.

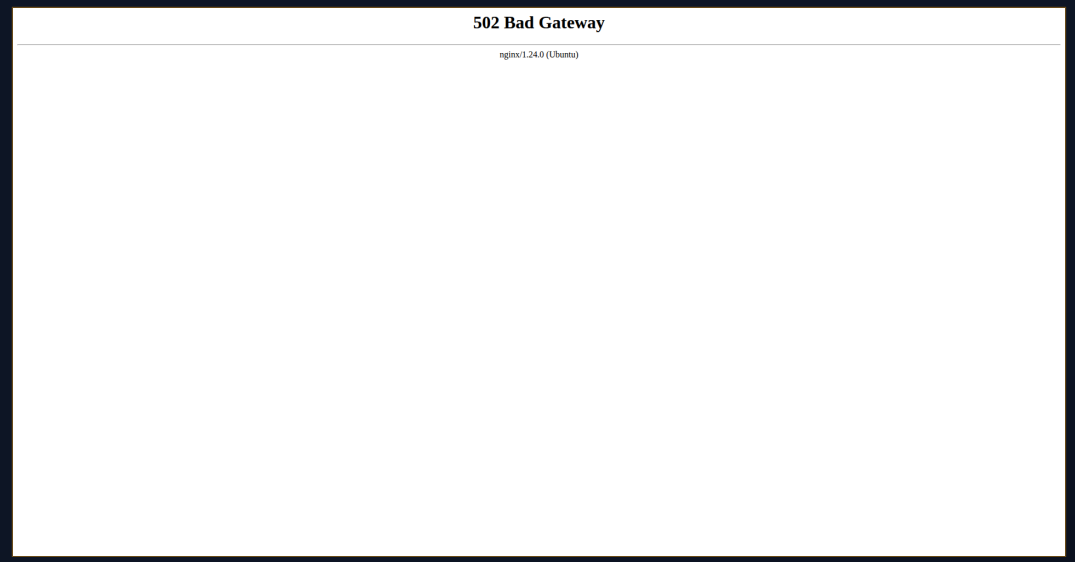
CONFIGURATION AUDIT

Built well, pinned poorly

- HIGH **The web interface is unmanaged.** No service definition, no container config, no restart policy exists for it anywhere in the repo — it was started by hand and left "untouched."
- MED **The rig runs below its own requirements:** framework versions on the rig violate the repo's minimums (offline package mirror), while the cloud gateway runs a much newer set. Two tiers, two different realities.
- MED **Nothing is pinned.** Dependencies are version ranges with no lockfile; the inference engine itself was built from an unpinned master branch. A redeploy today ≠ the September system.
- MED **No baseline web protections** in the repo's proxy config: no HSTS or security headers, server version disclosed.
- LOW **Hour-long timeouts** can pin the single quality-model slot for a full hour on one stuck request.

THE OUTAGE

Anatomy of the 502



- **Verified:** web front end down (502); API gateway alive (correct 401); school sites up. The failure is isolated to one container on the rig.
- **Most likely:** the hand-run interface container stopped or crashed — nothing in their stack restarts it or watches it.
- **Also likely:** a rig reboot restored every managed service (all auto-restart) and left the unmanaged one dead — exactly the split we observe.
- **Ruled out:** the stopped Ollama instance. It degrades chat inside the interface; it cannot cause a proxy-level 502 — the login page loaded fine with it stopped in September.
- **The finding beneath the finding:** the breakage lives in unmanaged runtime state — invisible to their repo, their board, and their status page.

DEBUGGING AUDIT

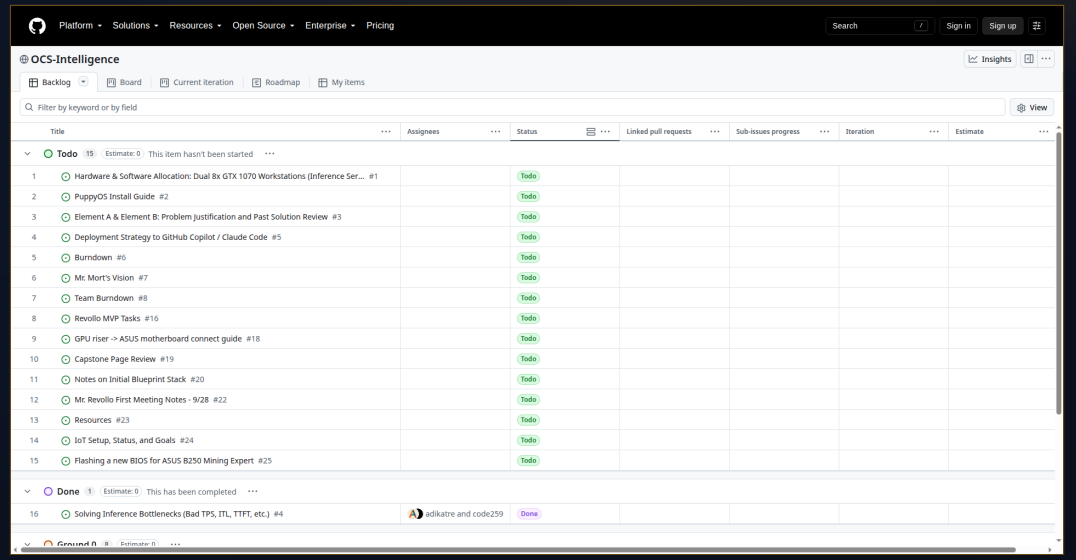
One real bug, one broken gate

- MED **Streaming breaks the capacity count.** For streamed replies — the main way students use it — the orchestrator releases its in-flight slot before generation even starts. The queue's capacity enforcement is effectively void for streaming.
- MED **Their own documentation checker fails on main** — 10 broken links from the September restructure. Nobody ran it. No CI exists to run it (next slide).
- LOW **Malformed JSON returns a 500 instead of a 400** in both services; a latent semaphore over-release hides in the lane code.
- **Coverage gap:** the passing tests cover lanes and benchmark math only — zero tests on authentication, routing, or health: precisely the security-critical code.
- **Done right:** upstream error details are deliberately swallowed into generic client messages — no internals leak.

PROJECT HEALTH

The record stopped; the work didn't

- HIGH **No CI at all.** No workflow directory exists — every check runs only when a student remembers.
- MED **Zero pull requests, ever.** All 30 commits pushed straight to an unprotected main — no review step, even for auth code.
- MED **Bus factor of two.** 2 of 6 students hold every commit; three have none. The handoff this project is graded on is untested.
- MED **Evidence stopped Sep 30.** The charter's Friday reports folder doesn't exist — yet board activity Oct 12–13 shows Rig 2 work continuing off-record.



Project board, today: two P0s closed, CI "in progress" — the repo shows it hasn't landed.

FOR THE WALKTHROUGH

Five questions for the team

- **1.** The interface is down and the API is up — who noticed, who owns uptime, and show me the recovery, from the runbook, live.
- **2.** Your auth fails open and the orchestrator trusts the whole network — walk me through closing both, and what breaks when you do.
- **3.** Where are the Week 2–3 playbooks and Friday reports? The record stopped September 30 — what changed?
- **4.** Worker A is slower than the baseline it replaced (8.7 vs 12.5 tok/s) — what's the NCCL decision, and by what date?
- **5.** Only two of you have committed code — can each of the other four run this system and explain it? That's the handoff test.

PATH FORWARD

From audit to showcase

- **At the walkthrough (Oct 19–21):** live recovery demo, rig tour, the five questions — then pitch practice begins.
- **Fix list, in order:** bring the interface under management with a restart policy + uptime check; fail-closed auth; firewall the orchestrator; individual student keys.
- **Restore the record:** backfill the weekly reports; turn on CI so the docs checker and tests run on every push; first pull request this week.
- **Prove the targets:** schedule the 8-user load test and the failure drills the charter promised — before Night at the Museum, not after.
- **The story for the showcase:** real students built a real service, measured it honestly, found it broken, fixed it in the open. That story wins rooms.